

Disk encryption

It is recommended that your disk be encrypted, and you use a strong passphrase that can be provided as input when booting the system. The Parabola wiki has useful documentation on disk encryption at https://wiki.parabola.nu/Disk_encryption. You can verify that the disk is encrypted using the following Ansible code snippet:

```
- name: Check disk is encrypted
  shell: lsblk /dev/sda | grep / | grep crypt
  register: encrypted

- assert:
  that:
    - "encrypted.rc == 0"
```

Mount options

The file systems that are mounted should have restrictive options, and use only what is required. The following commands check the *nosuid*, *nodev* and *noexec* options for the */tmp* and */dev/shm* directories:

```
- name: Check /tmp
  shell: mount | grep /tmp | grep -E 'nosuid.*nodev'
  register: tmp

- assert:
  that:
    - "tmp.rc == 0"

- name: Check /dev/shm
  shell: mount | grep /dev/shm | grep -E
'nosuid.*nodev.*noexec'
  register: tmp

- assert:
  that:
    - "tmp.rc == 0"
```

File access permissions

Access to */boot* and */etc/iptables* should be restricted to only users with privileged access. The following playbook snippet updates the 0700 permission for both the */boot* and */etc/iptables* directories.

```
- name: Change file mode for /boot, /etc/iptables
  file:
    path: "{{ item }}"
    mode: 0700
  with_items:
    - /boot
    - /etc/iptables
```

Lock out user

You can lock a user account after a certain number of failed logins by updating the */etc/pam.d/system-login* file as shown below:

```
- name: Update /etc/pam.d/system-login
  lineinfile:
    path: /etc/pam.d/system-login
    regexp: '^auth.*required.*pam_tally.so'
    line: 'auth      required    pam_tally.so          deny=2
unlock_time=600 onerr=succeed file=/var/log/faillog'
```

The account can only be unlocked after a certain time (*unlock_time*) or by the *root* user.

Limit the processes

In order to prevent Denial of Service (DoS) attacks, it is a good practice to limit the number of processes that a user can run. This policy can be updated in the */etc/security/limits.conf* file as shown below:

```
- name: Update /etc/security/limits.conf
  lineinfile:
    path: /etc/security/limits.conf
    insertbefore: '# End of file'
    line: "{{ item }}"
  with_items:
    - '* soft nproc 100'
    - '* hard nproc 200'
```

Restrict root login

You can restrict root login by allowing only users who belong to the *wheel* group to log in to *root* using *su*. The same needs to be updated in the */etc/pam.d/su* and */etc/pam.d/su-l* files as shown below:

```
- name: Update /etc/pam.d/su
  lineinfile:
    path: /etc/pam.d/su
    regexp: '^#auth      required    pam_wheel.so use_uid'
    line: 'auth      required    pam_wheel.so use_uid'

- name: Update /etc/pam.d/su-l
  lineinfile:
    path: /etc/pam.d/su-l
    regexp: '^#auth      required    pam_wheel.so use_uid'
    line: 'auth      required    pam_wheel.so use_uid'
```

Restrict access to kernel log

The output of *dmesg* can provide useful information to attackers and hence one needs to restrict access to it. The *ansible/files/* folder has both *50-dmesg-restrict.conf* and *50-kptr-restrict.conf* files, which need to be copied to *etc/sysctl.d* for the above functionality.